

Technical Requirements Document (TRD)

Project Name: CloudGuard GRC (AntiGravity Architecture)[cite: 1]

Document Version: 1.0.0 (MVP Infrastructure & Engineering Architecture)

Architecture Style: Serverless & Microservices-based Cloud Security Posture Management (CSPM) [cite: 1]

1. Frontend Stack

- Core Framework:** React.js (v18+) with TypeScript for static type safety and component modularity[cite: 1].
- State Management:** React Query (TanStack Query) for asynchronous server-state caching and state synchronization, combined with Zustand for lightweight client state management.
- Styling & UI Library:** TailwindCSS paired with `shadcn/ui` components for clean, accessible dashboard wireframes[cite: 1].
- Data Visualization & Analytics:** Recharts / Chart.js for rendering security posture trends, threat score matrices, and compliance scorecards[cite: 1].
- HTTP Client:** Axios with interceptors for JWT token injection and centralized API error handling.
- Build Tool & Bundler:** Vite for fast development compilation and optimized production builds.

2. Backend Stack

- Core Runtime & Framework:** Python 3.11+ using FastAPI for asynchronous, high-performance RESTful API endpoints[cite: 1].
- Cloud Provider SDK:** `boto3` for deep integration with AWS APIs (STS, IAM, S3, EC2, KMS, CloudTrail, Config)[cite: 1].
- Task Orchestration & Queueing:** AWS SQS + AWS Step Functions (or Celery with Redis) for distributed, asynchronous scan execution across multiple regions and accounts[cite: 1].
- Compliance & Rules Execution Engine:** Native Python rules engine running policy checks against AWS JSON responses, supplemented by Open Policy Agent (OPA) / Rego templates[cite: 1].
- Report Generation:** WeasyPrint / ReportLab for compiling audit-ready compliance PDF and CSV reports[cite: 1].

3. Database & Storage Architecture

Storage Component	Technology Selected	Technical Purpose
Primary Relational DB	AWS RDS PostgreSQL (v15+)[cite: 1]	Stores user accounts, tenant metadata, onboarded cloud account credentials, scan schedules, RBAC rules, and historical finding records[cite: 1].

Storage Component	Technology Selected	Technical Purpose
Cache & Queue Store	Redis / AWS ElastiCache	Stores active session tokens, rate-limiting counters, and temporary scan execution state.
Object Storage	AWS S3 (Server-Side Encrypted)[cite: 1]	Stores raw API JSON scan snapshots, full audit log backups, and generated PDF/CSV report artifacts[cite: 1].
Search Index (v2+)	Amazon OpenSearch Service[cite: 1]	Fast querying and filtering of millions of security findings across multi-account enterprises[cite: 1].

4. Authentication & Authorization Methods

- **User Authentication:** AWS Cognito User Pools / Auth0 implementing OAuth 2.0 and OIDC protocols with JWT bearer tokens[cite: 1].
- **Cross-Account Cloud Authentication:** Passwordless IAM Role Assumption using AWS STS (Security Token Service)[cite: 1].
 - The customer provisions a Read-Only IAM Role in their target AWS account[cite: 1].
 - CloudGuard GRC assumes this role via `sts:AssumeRole` using a unique `ExternalID` parameter to prevent Confused Deputy attacks[cite: 1].
- **Application RBAC:** Role-Based Access Control enforcing least privilege across 5 roles: *Super Admin*, *Cloud Account Admin*, *Security Analyst*, *Auditor (Read-Only)*, and *Viewer*[cite: 1].

5. APIs & System Endpoints

A. Internal Application REST APIs

HTTP Method	Endpoint Path	Description
POST	<code>/api/v1/auth/login</code>	Authenticates user credentials and issues JWT tokens[cite: 1].
POST	<code>/api/v1/accounts/onboard</code>	Validates and stores AWS IAM Role ARN and External ID[cite: 1].
POST	<code>/api/v1/scans/trigger</code>	Initiates an asynchronous cloud configuration scan[cite: 1].
GET	<code>/api/v1/findings</code>	Retrieves paginated findings filtered by severity, framework, or account[cite: 1].
GET	<code>/api/v1/reports/compliance</code>	Calculates scorecards for CIS, DPDPA, GDPR, and ISO 27001[cite: 1].
GET	<code>/api/v1/reports/export</code>	Generates and downloads audit-ready PDF/CSV compliance documents[cite: 1].

B. AWS Service APIs Invoked (Read-Only)

- `iam:ListAccessKeys` , `iam:GetAccountSummary` , `iam:ListUsers` (IAM Security Checks)[cite: 1]
- `s3:ListAllMyBuckets` , `s3:GetBucketAcl` , `s3:GetBucketPolicy` , `s3:GetBucketEncryption` (Storage Exposure)[cite: 1]

- `ec2:DescribeSecurityGroups` , `ec2:DescribeInstances` , `ec2:DescribeVpcFlowLogs` (Network Checks)[cite: 1]
- `cloudtrail:DescribeTrails` , `kms:ListKeys` , `config:DescribeComplianceByConfigRule` (Audit & Encryption)[cite: 1]

6. Rule Engines & Analysis Tools

- **Policy-as-Code Engine:** Implements rule logic derived from open-source benchmarks (Prowler, ScoutSuite, Cloud Custodian)[cite: 1].
- **Custom Rule Mapping:** Evaluates fetched AWS configuration state against framework control matrices (e.g., Unencrypted S3 Bucket → CIS AWS 2.1.1 → DPDPA Section 8 / GDPR Art. 32)[cite: 1].
- **laC Security Engine (CI/CD):** CLI integration with Checkov / TFSec for pre-deployment parsing of Terraform and CloudFormation templates[cite: 1].

7. Cloud Infrastructure & Deployment Setup

- **Cloud Provider:** AWS (Amazon Web Services)[cite: 1].
- **Backend Deployment:** Containerized microservices running on AWS ECS Fargate or serverless worker tasks using AWS Lambda[cite: 1].
- **Frontend Hosting:** Static site hosting via AWS S3 bucket distributed through Amazon CloudFront CDN with SSL/TLS edge certificates[cite: 1].
- **Infrastructure as Code (laC):** Terraform modules defining the entire app environment (VPC, ECS, RDS, SQS, S3, IAM Roles)[cite: 1].
- **CI/CD Pipeline:** GitHub Actions workflow executing automated linting, unit testing (via `pytest`), Docker image building, scanning, and zero-downtime deployment to AWS[cite: 1].

8. Security Requirements

- **Least Privilege Execution:** All customer scanning IAM roles strictly enforce read-only policy boundaries (`*ReadOnlyAccess`` policies)[cite: 1].
- **Encryption Standards:**
 - *At Rest:* AWS KMS AES-256 bit encryption applied across RDS PostgreSQL databases, S3 storage buckets, and SQS queues[cite: 1].
 - *In Transit:* Mandatory TLS 1.3 encryption across all internal API endpoints, HTTPS web traffic, and AWS SDK calls[cite: 1].
- **Confused Deputy Protection:** Unique `ExternalID` validation required for all cross-account role assumptions[cite: 1].
- **Data Isolation:** Strict multi-tenant logical segregation enforced in the PostgreSQL database layer using Tenant IDs.
- **Audit Logging:** All system activities, user access events, and scan executions logged to AWS CloudWatch with a 1-year retention policy for auditing[cite: 1].

9. Performance & Scale Requirements

- **Scan Velocity:** A full scan of a single AWS account region must complete in under 3 minutes[cite: 1].
- **Parallel Scaling:** SQS queue workers scale dynamically to handle scans across hundreds of connected AWS accounts simultaneously[cite: 1].
- **API Latency:** Dashboard REST APIs must respond in < 200ms for p95 requests.
- **API Rate Limit Mitigation:** Scans implement exponential back-off retries and paginated calls to comply with AWS API quota limits[cite: 1].

10. Third-Party Integrations

- **Alerting & Notifications:** Slack Webhooks, Microsoft Teams, and Amazon SNS (Email/SMS notifications)[cite: 1].
- **ITSM & Ticketing Systems:** Jira REST API and ServiceNow integration for automated issue ticket generation[cite: 1].
- **SIEM Platforms:** Export event streams to Splunk, IBM QRadar, and AWS Security Hub[cite: 1].
- **Developer CI/CD Tooling:** GitHub Actions plugin and CLI hooks for IaC pipeline scanning[cite: 1].